Lab 04 — Control gaps and a crisis tabletop

Course: Maxim Nyansa Cybersecurity Bootcamp, Ghana
Trainee: James Ackah Blay · Aiyinasi, Ghana
Week: 4 — Security management, risk, and governance
Estimated time: 4 hours
Difficulty: Intermediate. You will separate “a document exists” from “a control works”.

Tutor note. Practical platform: the GRC Lab at https://grclab.purplecop.io/lab . This guide does not describe that product. ISO/IEC 27001 is a management-system standard. A student checklist does not certify anyone. Do not paste the text of the standard into the repository.

1. Learning objectives

Objective	Job skill
Score likelihood and impact with a written reason	Risk acceptance a manager can sign
Compare evidence with a control question	Internal audit and GRC fieldwork
Run a discussion-based incident	Tabletop facilitation, which is a SOC and GRC skill
Write a finding that does not overclaim	Audit working papers

2. Prerequisites and setup

Week 1 risk language and the Palm Court scenario, or your own lab assets if they now exist. The Week 4 project folders already contain the sprint CSV, the gap checklist, the audit paper, and the tabletop scenario. This lab tells you the order and the standard.

Use the GRC Lab for the assessment work, then file evidence in the project folder you used.

3. Scenario

The same small lab is now being asked, “Are you ready if the Ubuntu VM shows a new sudo account you did not create?” You will not attack anything. You will score risks, test whether your documents are evidence, and walk a tabletop.

4. Tasks

Task 1 — Risk sprint

Open `../risk-assessment-sprint/`. Copy forward any Week 1 risk you still believe. Score only with a reason in the notes column. Use score = likelihood × impact, the same 1 to 5 scales as Lab 01.

> **You should now see** at least three rows with `example=no`, an owner, and a treatment. Example rows in that folder stay marked as examples.

Task 2 — Spot the gap

Open `../iso-27001-gap-check/gap-checklist.csv`. For each row, look for evidence in this repository or on your VM. Status values are `met`, `partial`, `gap`, or `not-reviewed`.

A `met` row must name a file you can open. “We talked about it” is `partial` at best. If you cannot see it, leave `not-reviewed`.

The four Annex A themes in the 2022 edition are organisational, people, physical, and technological. The checklist uses those themes in plain language. It is not a copy of the standard.

Task 3 — Role-play audit

In `../role-play-audit/audit-findings.md`, swap roles. One person asks for evidence. One shows it. One writes. Choose two controls from the gap checklist.

> **You should now see** two findings. A missing document is a finding about evidence. Do not upgrade “the file exists” into “the control operates” unless you saw it operate.

Task 4 — Tabletop

Use `../tabletop-crisis-simulation/scenario.md`. Read one inject at a time. Write the decision in `decision-log.csv` before you read the next inject.

The story is fiction. Do not file it as an incident at Maxim Nyansa or on your laptop. When someone suggests “trying the same thing back” at an address, the decision you record is a refusal unless that address is inside a written lab scope. You do not have that scope this week.

Task 5 — GRC Lab evidence

After you use the GRC Lab, save the export in the project folder and note the file name in your sprint notes. Leave the line blank if you have not been there. Do not describe menus you have not seen.

5. Troubleshooting

What you see	What it means
Every control is `met` in ten minutes	You marked documents as operating controls. Re-read Task 2
The tabletop becomes a hacking story	Stop. Return to decisions, evidence, and who you would tell
You cannot find an owner	The risk is not finished. An owner is a name, including your own

6. Stretch task

Pick the highest score in your sprint. Write the sentence you would say to a non-technical owner in under 30 seconds: what can go wrong, what you recommend, and what you are not claiming.

7. Evidence

- Sprint rows that are yours.
- Gap checklist with statuses you can defend.
- Two audit findings.
- A decision log with at least four rows.
- GRC Lab file, or an explicit blank.

8. Reflection

1. Which control did you almost mark `met` without evidence?
2. What did the tabletop ask for that your lab cannot yet prove?
3. Where did Act 843 show up, even though this week felt like “management”?

9. Interview questions

1. What is the difference between ISO 27001 and a checklist you wrote?
2. How do you write a finding when the evidence is missing?
3. What is a tabletop, and what is it not?
4. How do you explain a high risk to someone who does not read matrices?

10. Grading rubric

Criterion	Exceeds	Meets	Not yet
Scoring	Reasons would survive a challenge	Numbers, owners, treatments	Example rows relabelled as yours
Gap review	`met` rows cite files	Honest mix of statuses	All `met` with empty evidence
Audit	Findings separate what was shown from what was missing	Two findings	Praise with no gap
Tabletop	Decisions include a refusal to strike back	Log has a row per inject	A story with no decisions